REPORTE TÉCNICO · MAPEO 5

Seguridad en Aplicaciones Móviles AppSec & SAST (Android APK)

AIACO Corp — Análisis estático con MobSF y hardening Blue Team

ANALISTA

Jesús Alejandro Rodríguez Medina

ROL

DevSecOps / Analista de Ciberseguridad Jr.

ORGANIZACIÓN / PROYECTO

AIACO Corp — Attack Surface Management (ASM)

VECTOR DE ATAQUE

Aplicación Móvil (Android APK)

HERRAMIENTA PRINCIPAL

MobSF (Mobile Security Framework) en Docker

METODOLOGÍA

OWASP MASVS

OWASP MASVS | SAST — Análisis Estático | Red Team → Blue Team

ID: REP-ASM-2026-MOB01

• SECURITY SCORE INICIAL: 52 / 100

1. Ficha General del Documento

Campo	Detalle
Código del Documento	`REP-ASM-2026-MOB01`
Título	Reporte Técnico — Mapeo 5: Seguridad en Aplicaciones Móviles (AppSec & SAST)
Organización	AIACO Corp
Proyecto Marco	Attack Surface Management (ASM)
Analista Responsable	Jesús Alejandro Rodríguez Medina — DevSecOps / Analista de Ciberseguridad Jr.
Vector de Ataque	Aplicación móvil (Android APK)
Metodología	OWASP MASVS (Mobile Application Security Verification Standard)
Estado	COMPLETADO

2. Resumen Ejecutivo

El presente reporte documenta el quinto mapeo del programa de Attack Surface Management (ASM) para **AIACO Corp**, enfocado en la capa de aplicaciones móviles. Se ejecutó un Análisis Estático de Seguridad (SAST) sobre un APK de prueba de respaldo de la aplicación móvil, con el propósito de identificar vulnerabilidades en el código, exposición de configuraciones, permisos en el manifiesto y fallas de autorización de API, para posteriormente aplicar el hardening necesario.

El análisis se realizó con **Mobile Security Framework (MobSF)** desplegado en contenedores **Docker**. El escaneo inicial arrojó un **Security Score de 52 / 100**, con 1 advertencia en Manifest Analysis, 0 vulnerabilidades y 3 advertencias en Code Analysis, además del log de plataforma `DEP 0040`. Los riesgos principales identificados fueron **problemas de autorización de API** y **exposición de información en archivos XML y JSON**.

Como respuesta, el equipo Blue Team ajustó el archivo `app.json`, corrigió la autorización de la API y generó un nuevo binario limpio, `fixes.apk`, verificando posteriormente la mitigación de las advertencias señaladas en Manifest y Code Analysis.

SECURITY SCORE INICIAL	MANIFEST (ADVERTENCIAS)	CODE (VULNERAB. / ADVERT.)	BINARIO CORREGIDO
52 / 100	1	0 / 3	fixes.apk

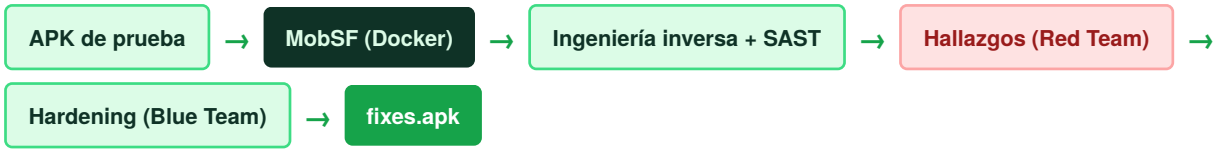
3. Metodología (OWASP MASVS)

La evaluación se alineó con **OWASP MASVS** (Mobile Application Security Verification Standard), estándar de referencia para verificar la seguridad de aplicaciones móviles, bajo un enfoque de **análisis estático (SAST)**: el binario se examina sin ejecutarlo, mediante ingeniería inversa y escaneo automatizado.

3.1. Entorno y Herramientas

Elemento	Detalle
Entorno de análisis	Contenedores Docker
Herramienta principal	Mobile Security Framework (MobSF)
Objeto de análisis	APK de prueba de respaldo (aplicación móvil AIACO Corp)
Archivos revisados	Binario APK, `app.json` y archivos de configuración XML

3.2. Flujo de la Evaluación

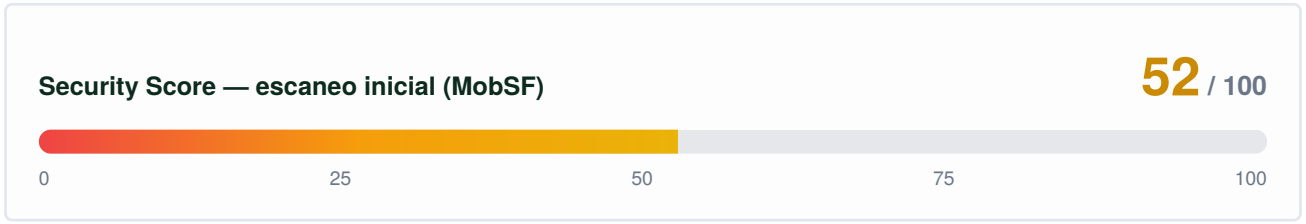


3.3. Fases Ejecutadas

Fase	Descripción
Fase 1 — Red Team	Diagnóstico y escaneo: se sometió el APK de prueba a ingeniería inversa y escaneo automatizado con MobSF para identificar configuraciones expuestas, permisos y fugas en la autorización de APIs.
Fase 2 — Blue Team	Remediación y hardening: corrección de las configuraciones señaladas y generación de un nuevo binario seguro, seguido de validación final de las advertencias.

4. Resultados del Escaneo SAST

4.1. Calificación Inicial (Security Score)



4.2. Resumen de Hallazgos por Módulo

Módulo	Resultado	Descripción
Advertencia de Plataforma	Log DEP 0040	Identificado durante la carga y deconstrucción del entorno de análisis.
Manifest Analysis	1 advertencia	Permisos y configuraciones potencialmente inseguras en la declaración de `AndroidManifest.xml`.
Code Analysis	0 vulnerabilidades 3 advertencias	Prácticas de código que requieren revisión, incluyendo exposición de esquemas de autorización de API y metadatos en archivos JSON.

4.3. Riesgos Identificados

Problemas de autorización de API

Advertencia

Exposición de esquemas de autorización de la API en el código de la aplicación, que permitía consultas sin validación adecuada (consultas anónimas o sin token).

Exposición en archivos XML y JSON

Advertencia

Variables de entorno y metadatos expuestos en la configuración del framework (`app.json`) y archivos XML, susceptibles de revelar información sensible a partir de la ingeniería inversa del APK.

Configuración del Manifest

Advertencia

Una advertencia en Manifest Analysis por permisos o configuraciones potencialmente inseguras en `AndroidManifest.xml`.

4.4. Correlación con Dominios OWASP MASVS

Correlación orientativa entre los hallazgos y los dominios de control de MASVS, útil para priorizar el hardening:

Hallazgo	Dominio MASVS (referencia)	Observación
Autorización de API	`MASVS-AUTH`	Validación de identidad/token en el consumo de la API.
Exposición en XML / JSON	`MASVS-STORAGE` · `MASVS-CODE`	Datos y configuraciones sensibles embebidos en el binario.
Manifest Analysis	`MASVS-PLATFORM`	Interacción segura con la plataforma Android y permisos declarados.

5. Acciones de Remediación (Blue Team)

Con base en el reporte de MobSF se parchó la aplicación y se generó un nuevo binario seguro, `fixes.apk`.

1. **Revisión de autorización de API:** se ajustaron los parámetros de validación para el consumo de la API, evitando consultas anónimas o sin token.
2. **Hardening de `app.json`:** se modificaron las variables de entorno y metadatos expuestos en la configuración del framework (JSON y XML) para ofuscar información sensible.
3. **Generación de binario limpio:** compilación de `fixes.apk` con las correcciones aplicadas.
4. **Validación final:** verificación de las advertencias emergentes, confirmando la mitigación de los riesgos señalados en Manifest Analysis y Code Analysis.

5.1. Estado Antes / Después

ANTES — APK de prueba

- Security Score: 52 / 100
- 1 advertencia en Manifest Analysis
- 3 advertencias en Code Analysis
- Autorización de API con exposición
- Metadatos expuestos en XML / JSON

DESPUÉS — fixes.apk

- Validación de API: sin consultas anónimas ni sin token
- `app.json` endurecido
- Información sensible ofuscada
- Advertencias de Manifest y Code mitigadas

5.2. Matriz de Remediación

Riesgo	Acción correctiva	Estado
Autorización de API	Ajuste de parámetros de validación; se evitan consultas anónimas o sin token.	Remediado
Exposición en XML / JSON	Hardening de `app.json`; ofuscación de variables de entorno y metadatos.	Remediado
Advertencia de Manifest	Corrección validada mediante nueva verificación sobre `fixes.apk`.	Mitigado
Log DEP 0040	Advertencia de plataforma/entorno de análisis; registrada como informativa.	Informativo

6. Conclusión

El análisis estático permitió identificar, sin necesidad de ejecutar la aplicación, que el APK de prueba de AIACO Corp presentaba una postura de seguridad intermedia (52 / 100), sin vulnerabilidades en Code Analysis pero con advertencias relevantes en autorización de API y exposición de configuraciones. Las acciones del Blue Team —

hardening de `app.json`, corrección de la autorización de API y generación de `fixes.apk` — permitieron mitigar los riesgos señalados en Manifest Analysis y Code Analysis.

Este mapeo concluye el ciclo del programa de Attack Surface Management (ASM) para AIACO Corp, cubriendo exitosamente la capa de infraestructura móvil.

Jesús Alejandro Rodríguez Medina
DevSecOps / Analista de Ciberseguridad Jr.
AIACO Corp

✔ MAPEO 5 COMPLETADO